# SIMATS ENGINEERING
## ASSESSMENT TOOL 3

**COURSE NAME: Ethical Hacking** **COURSE CODE: ITA14**

### COURSE OUTCOME COVERED

**CO2:** Execute footprinting in social engineering such as DNS analysis, competitive intelligence gathering, and attack simulations to collect relevant information for identifying potential security risks.. (BT4)

*Assessment Tool Weightage: 30%*

**Duration: 90 min** **Total Marks: 50**

## Scenario-Based Assessment

**Topic 1: Footprinting Tools – Conducting Competitive Intelligence**

**Q1. (L3 – Apply) – 15 Marks**

A cybersecurity consultant has been assigned to perform a passive security assessment for a company named ABC Technologies. The consultant must collect publicly available information without directly interacting with the company's servers.

**Task:** Apply suitable footprinting tools to identify the company's:

- domain registration details,
- employee email addresses,
- technology stack,
- and publicly exposed subdomains.

Explain how each selected tool helps in conducting competitive intelligence.

**Answer:**

## 1. Understanding the Scenario

ABC Technologies needs a passive security assessment. Passive footprinting means collecting only publicly available information (OSINT) from third-party sources such as WHOIS databases, search engines and certificate logs, without sending packets to the company's own servers. This avoids detection and stays within the legal scope, and the same data is what a business competitor or an attacker would collect for competitive intelligence.

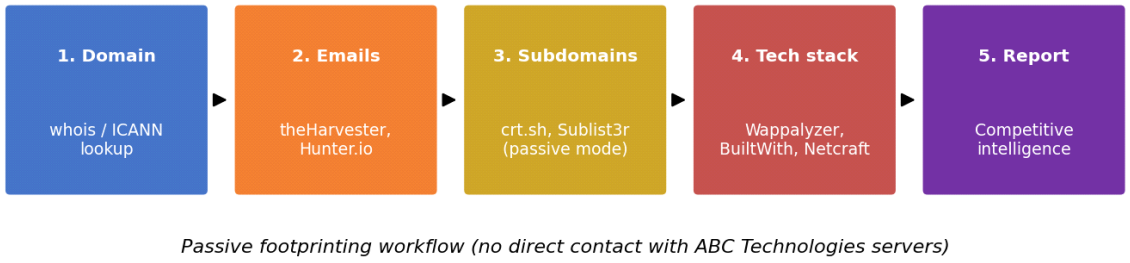



*Figure 1: Passive footprinting workflow for ABC Technologies*

## 2. Tools Selected and How Each Helps

| Information Needed | Tool(s) | Command / Method | How it Helps Competitive Intelligence |
|---|---|---|---|
| Domain registration details | whois, ICANN Lookup, DomainTools | whois abctechnologies.com | Shows registrar, creation and expiry dates, registrant organisation, name servers and country; reveals company age, hosting provider and DNS infrastructure. |
| Employee email addresses | theHarvester, Hunter.io, Google dorks | theHarvester -d abctechnologies.com -b crtsh,duckduckgo | Reveals the email format (for example firstname.lastname@) and public mailboxes, showing departments and contacts. |
| Technology stack | Wappalyzer, BuiltWith, Netcraft, Shodan | Browser plug-in or web lookup of the domain | Identifies CMS, web server, programming language, analytics, CDN and hosting; shows which technologies the company relies on and their versions. |
| Publicly exposed subdomains | crt.sh, Sublist3r (passive), theHarvester, | sublist3r -d abctechnologies.com / | Lists portals, mail, VPN, development and |

| | | | |
|---|---|---|---|
| | Amass (passive) | crt.sh query %.abctechnologies.com | staging hosts, revealing products, services and possible forgotten systems. |

## 3. Commands and Sample Results

```
$ whois abctechnologies.com
```




*Figure 2: WHOIS output showing registration details (illustrative sample)*

```
$ theHarvester -d abctechnologies.com -l 200 -b
crtsh,hackertarget,otx,duckduckgo
```




*Figure 3: Emails and subdomains collected from public sources (illustrative sample)*

- **Domain registration:** registered in 2012 through GoDaddy, owner ABC Technologies Pvt. Ltd., two name servers, DNSSEC not enabled. Personal data is hidden by privacy protection.
- **Emails:** info@, hr@, support@, sales@ and it.admin@ were found, which shows the email format and the departments.
- **Subdomains:** www, mail, blog, portal, dev and vpn were found; dev and vpn are interesting because they point to development and remote-access systems.
- **Technology stack (from Wappalyzer / BuiltWith):** for example Apache or Nginx web server, WordPress CMS, PHP, Google Analytics and Cloudflare CDN, which show what software the company runs.

## 4. How the Tools Support Competitive Intelligence

- WHOIS and DNS data show the age of the company's online presence, its hosting provider and partners.

- Email and subdomain data show the organisational structure, active product portals and new services (for example a new "beta" or "app" subdomain hints at an upcoming product).
- Technology profiling shows what tools, platforms and vendors the company uses, which helps to compare competitors and to find possible security weaknesses.
- The same information can be misused for phishing and targeted attacks, so the company should reduce what it exposes (WHOIS privacy, careful DNS and certificate naming, removal of old subdomains and unneeded public email addresses).

**Conclusion:** By combining WHOIS, theHarvester, certificate-transparency/subdomain tools and technology profilers, the consultant can build a complete picture of ABC Technologies passively, without touching its servers.

**Topic 2: DNS Zone Transfers**

**Q2. (L3 – Apply) – 15 Marks**

During an authorized penetration test, a security analyst suspects that the target organization's DNS server is misconfigured and may allow unauthorized DNS zone transfers.

**Task:** Apply the appropriate DNS command or tool to verify whether zone transfers are permitted. If the transfer succeeds, explain how the retrieved DNS records can be used to identify internal hosts, mail servers, and subdomains during reconnaissance.

**Answer:**

**1. Understanding the Scenario**

A DNS zone transfer (AXFR) is a mechanism to copy a whole DNS zone from a primary name server to a secondary server. If the server is misconfigured to accept AXFR requests from any host, anyone can download the complete list of DNS records. The analyst must verify this during the authorised test.

**2. Tools and Commands to Verify Zone Transfer**

- **Step 1 – Find the name servers:** identify the authoritative name servers of the domain.

```
$ dig NS abctechnologies.com +short
```

- **Step 2 – Request a zone transfer from each name server:**

```
$ dig axfr abctechnologies.com @ns1.abctechnologies.com
$ host -l abctechnologies.com ns1.abctechnologies.com        # alternative
$ nslookup  ->  server ns1.abctechnologies.com  ->  ls -d
abctechnologies.com
$ dnsrecon -d abctechnologies.com -t axfr                    # automated,
all name servers
$ fierce --domain abctechnologies.com                        # also tries
AXFR
```

- **Step 3 – Interpret the result:** if the records are returned, the server is vulnerable; if the answer is "Transfer failed" or REFUSED, the server is configured securely. Each name server must be tested separately, because one may be misconfigured.

## 3. Results

```
kali@kali: ~
$ dig NS abctechnologies.com +short
ns1.abctechnologies.com.
ns2.abctechnologies.com.
$ dig axfr abctechnologies.com @ns1.abctechnologies.com
; <<>> DiG 9.18 <<>> axfr abctechnologies.com @ns1.abctechnologies.com
abctechnologies.com.        3600 IN SOA  ns1.abctechnologies.com. admin.abctechnologies.com. (...)
abctechnologies.com.        3600 IN NS   ns1.abctechnologies.com.
abctechnologies.com.        3600 IN MX   10 mail.abctechnologies.com.
mail.abctechnologies.com.   3600 IN A    10.10.20.25
vpn.abctechnologies.com.    3600 IN A    10.10.20.40
dev.abctechnologies.com.    3600 IN A    10.10.20.55
db01.abctechnologies.com.   3600 IN A    10.10.30.10
intranet.abctechnologies.com. 3600 IN A  10.10.30.20
test-erp.abctechnologies.com. 3600 IN CNAME dev.abctechnologies.com.
;; XFR size: 11 records  -->  ZONE TRANSFER SUCCEEDED (vulnerable)
```

*Figure 4: Successful zone transfer on ns1 (vulnerable) – illustrative sample*

```
kali@kali: ~
$ dig axfr abctechnologies.com @ns2.abctechnologies.com
; <<>> DiG 9.18 <<>> axfr abctechnologies.com @ns2.abctechnologies.com
;; global options: +cmd
; Transfer failed.
(secure server: transfer refused, only authorised secondary servers are allowed)
$ dnsrecon -d abctechnologies.com -t axfr
[*] Checking for Zone Transfer for abctechnologies.com name servers
[-] Zone Transfer Failed for ns1 (REFUSED)
```

*Figure 5: Refused zone transfer on a secure name server – illustrative sample*

## 4. Using the Retrieved Records During Reconnaissance




*Figure 6: Information obtained from each record type*

| Goal | Records Used | What the Analyst Learns |
|---|---|---|
| Identify internal hosts | A / AAAA records (for example db01, intranet, dev) | Hostnames and IP addresses of internal or private servers (10.10.x.x ranges), database and intranet systems, and the network layout and subnets; naming shows the purpose of each machine. |
| Identify mail servers | MX records (with their A records), SPF in TXT | Which servers handle email and their priority, plus the mail provider; these are targets for phishing, relay testing and mail-server vulnerabilities. |
| Identify | A, CNAME and NS records | Complete list of subdomains, including |

| | | |
|---|---|---|
| subdomains | | hidden, test and staging hosts (for example test-erp), third-party services pointed to by CNAME, and possible subdomain takeover candidates. |
| Other useful data | SOA, NS, SRV, TXT, PTR | Administrator contact, name server details, service locations (LDAP, Kerberos, SIP), and verification strings for third-party services. |

With this list the analyst can select high-value targets (database, VPN, development hosts), plan the port and vulnerability scans, and prepare social engineering scenarios. No noisy scanning is needed, so this reconnaissance is quick and hard to detect.

**5. Findings and Recommendations**

- **Risk:** information disclosure that gives attackers a complete map of the infrastructure (High).
- **Fix:** restrict zone transfers to authorised secondary servers by IP (allow-transfer { trusted-IP; }), secure transfers with TSIG, use split-horizon DNS to keep internal names private, remove stale records, and monitor AXFR attempts in DNS logs.
- **Re-test:** repeat dig axfr from an external host to confirm the transfer is now refused.

**Conclusion:** The test shows whether the DNS server leaks its zone. If it does, the records expose internal hosts, mail servers and subdomains, so zone transfers must be limited to trusted servers only.

**Topic 3: Introduction to Social Engineering – Social Engineering Attacks and Countermeasures**

**Q3. (L3 – Apply) – 20 Marks**

Employees of an organization receive an email claiming to be from the IT department, asking them to verify their login credentials through a provided link because of an urgent security update.

Task: Identify the type of social engineering attack and apply suitable countermeasures that employees should follow before responding to the email. Explain how these actions help prevent credential theft.

**Answer:**

**1. Type of Social Engineering Attack**

The email is a phishing attack, specifically credential-harvesting phishing that uses impersonation (pretexting as the IT department). Because it was sent to many employees at once it is a mass (deceptive) phishing campaign; if it were addressed to named individuals it would be

spear-phishing. It relies on authority (claims to be IT), urgency ("urgent security update") and fear (account loss) to make users click the link and enter their credentials on a fake login page.

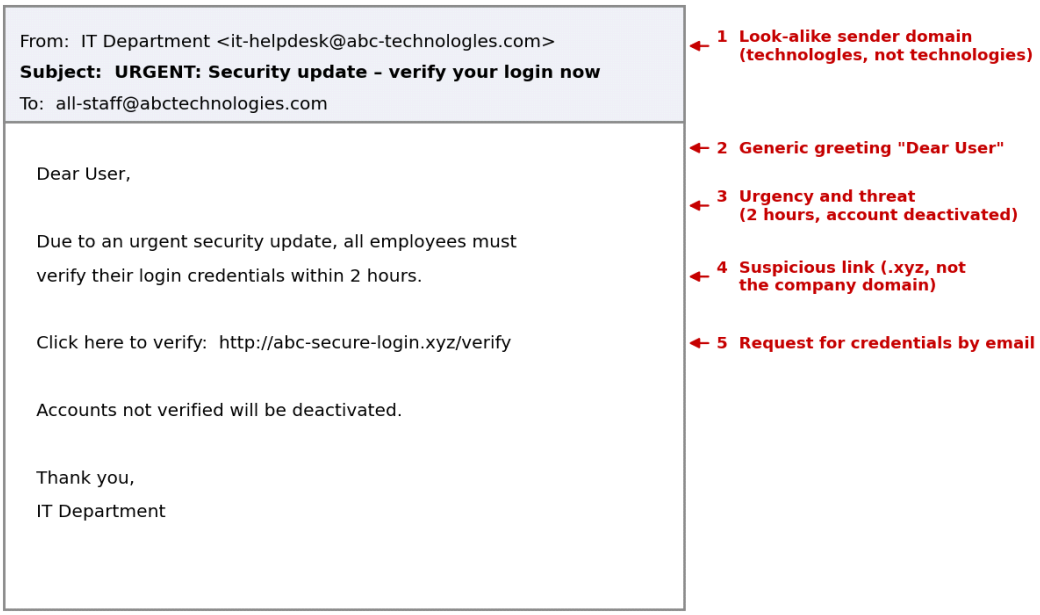



*Figure 7: Sample phishing email with warning signs marked*

## 2. Warning Signs in the Email

- **Spoofed or look-alike sender:** the address resembles the company domain but is not exactly the same.
- **Urgency and threats:** "within 2 hours" and "accounts will be deactivated" are used to stop the user from thinking.
- **Generic greeting:** "Dear User" instead of the person's name.
- **Suspicious link:** the visible or hidden URL points to a domain that is not the company's (for example .xyz).
- **Request for credentials:** the IT department never asks users to verify passwords by email.

## 3. Countermeasures Employees Should Follow Before Responding




*Figure 8: Employee checklist before responding to a suspicious email*

| Countermeasure (Action) | How to Do It | How it Prevents Credential Theft |
|---|---|---|
| 1. Do not click or reply | Do not open links or attachments; do not reply to the email. | Stops the user from reaching the fake login page or downloading malware. |
| 2. Check the sender address | Open the full address and check for spelling changes in the domain. | Exposes spoofed or look-alike domains. |
| 3. Hover over the link | Move the mouse over the link (without clicking) and read the real URL; check HTTPS and the domain. | Shows that the link leads to a fake site, so the password is never typed there. |
| 4. Verify through a separate channel | Call or message the IT help desk using the number from the company directory or intranet, not from the email. | Confirms whether the request is genuine and defeats impersonation. |
| 5. Never share credentials | Passwords are never given by email, phone or links; go to the official portal by typing its address or using a bookmark. | Even if the user is deceived, no credentials reach the attacker. |
| 6. Report the email | Use the Report Phishing button or forward to the security team. | Lets the security team block the sender and URL and warn other employees. |
| 7. If already clicked or entered data | Disconnect from the network, change the password immediately, tell IT, and check for unknown logins. | Limits the time the stolen password is usable and stops further damage. |
| 8. Use MFA and a password manager | Enable multi-factor authentication; a password manager only fills passwords on genuine domains. | A stolen password alone cannot log in, and the manager will not auto-fill on a fake site. |

**4. Organisational Support Measures**

- Email filtering with SPF, DKIM and DMARC to block spoofed messages, and link/attachment scanning.
- Regular awareness training and simulated phishing campaigns.
- A clear policy stating that IT will never ask for passwords by email, and a quick incident response procedure.

**Conclusion:** The scenario is a credential-harvesting phishing attack using IT impersonation and urgency. If employees stop, check the sender and link, verify through a trusted channel, report the message and use MFA, the attacker cannot obtain usable credentials.

***Code of Conduct:***

*I **HASTHAVARAM SANJAY REDDY, 192372056** (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.*
*I understand that any violation of academic integrity rules will result in disciplinary action.*

***Signature of the student:*** *Hasthavaram Sanjay Reddy*

## RUBRICS FOR CALCULATION

| Scenario Based Assessment | | | | | |
|---|---|---|---|---|---|
| **Criteria** | **Weightage (%)** | **Level 4 (Exemplary)** | **Level 3 (Proficient)** | **Level 2 (Developing)** | **Level 1 (Beginning)** |
| Understanding of Scenario | 20% | Demonstrates clear and complete understanding of the scenario and context | Shows good understanding with minor gaps | Partial understanding; misses key aspects | Misinterprets or fails to understand the scenario |
| Identification of Key Issues | 20% | Accurately identifies all relevant issues and factors involved | Identifies most key issues with minor omissions | Identifies limited issues; some irrelevant points | Unable to identify key issues |
| Application of Concepts | 25% | Applies appropriate concepts effectively to | Applies concepts with minor errors | Limited or partially correct application | Unable to apply relevant concepts |

| | | | | | |
|---|---|---|---|---|---|
| | | address the scenario | | | |
| Decision Making | 20% | Makes well-reasoned, logical decisions with strong rationale | Makes reasonable decisions with some justification | Makes weak decisions with limited justification | No clear decisions made or rationale provided |
| Clarity of Response | 15% | Response is clear, structured, and logically presented | Generally clear with minor issues | Somewhat unclear or poorly structured | Disorganized and difficult to understand |